

SYSTEM INSTRUCTION FOR OPENCODE AGENT: E-ITS IAM & TENANT DATABASE DESIGN

1. Project Context & Compliance Framework You are tasked with developing the backend database architecture for a multi-tenant compliance and security management application based on the Estonian Information Security Standard (E-ITS – *Eesti infoturbestandard*). E-ITS is a risk-based baseline security framework derived from BSI IT-Grundschutz and is compatible with ISO/IEC 27001 1, 2. The application will be used to manage IT security measures and collect technical evidence (*tehniline evidents*) for audits conducted by the Estonian Information System Authority (RIA – *Riigi Infosüsteemi Amet*).

2. Architectural Paradigm: Database-per-Tenant To strictly comply with E-ITS data isolation requirements for service providers, you must implement a "Database-per-Tenant" (*isoleeritud rentniku mudel*) architecture 3, 4.

- **Tier A (Central DB):** Manages global routing, tenant registries, and central authentication (Single Sign-On / SSO) (*keskne autentimisteenus*) 5.
- **Tier B (Tenant DBs):** Dynamically provisioned isolated databases for each client. Stores local user profiles, E-ITS specific roles (*E-ITS standardrollid*), and audit trails (*auditijälg*).

3. Database Technology Stack & Rules

- **Engine:** PostgreSQL.
- **Primary Keys:** Use UUIDv4 (via `gen_random_uuid()`) instead of serial integers to prevent enumeration attacks and ensure uniqueness across distributed systems 6, 7.
- **Security:** Passwords must never be stored in plain text; use robust hashing (e.g., `bcrypt/argon2`) to meet E-ITS authentication data protection requirements 8. Prevent SQL injection by strictly using parameterized queries 9.

TIER A: Central Management Database Schema (Keskne haldusbaas)

Execute this DDL in the central routing database.

```
-- Enable pgcrypto for secure UUID generation
CREATE EXTENSION IF NOT EXISTS "pgcrypto";

-- 1. Tenant Registry (Klientide baastabel)
CREATE TABLE tenants (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    name VARCHAR(255) NOT NULL,
    db_name VARCHAR(100) NOT NULL UNIQUE, -- The isolated database
name for the tenant
    status VARCHAR(50) DEFAULT 'active',
    created_at TIMESTAMPTZ DEFAULT CURRENT_TIMESTAMP
);

-- 2. Global Identity & Authentication (Tsentraalne identiteet)
```

```

-- Complies with E-ITS central authentication requirements (ORP.4 -
Identiteedi- ja õiguste haldus)
CREATE TABLE global_users (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    email VARCHAR(255) UNIQUE NOT NULL,
    password_hash VARCHAR(255) NOT NULL, -- Must be securely hashed
and salted
    created_at TIMESTAMPTZ DEFAULT CURRENT_TIMESTAMP
);

-- 3. Tenant-User Mapping (Seostetabel)
CREATE TABLE tenant_users (
    tenant_id UUID REFERENCES tenants(id) ON DELETE CASCADE,
    user_id UUID REFERENCES global_users(id) ON DELETE CASCADE,
    assigned_at TIMESTAMPTZ DEFAULT CURRENT_TIMESTAMP,
    PRIMARY KEY (tenant_id, user_id)
);

```

TIER B: Tenant-Specific Database Schema (Kliendipõhine andmebaas)

This schema must be deployed automatically to every new tenant database via CI/CD pipelines (*pideva integratsiooni ja tarnimise torujuhtmed*) and Infrastructure as Code (IaC) (*taristu koodina*) principles.

```

CREATE EXTENSION IF NOT EXISTS "pgcrypto";

-- 1. Local User Profiles (Kohalikud kasutajaprofiilid)
CREATE TABLE local_users (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    global_user_id UUID NOT NULL UNIQUE, -- Foreign reference to Tier
A global_users.id
    full_name VARCHAR(255) NOT NULL,
    department VARCHAR(100),
    mfa_enabled BOOLEAN DEFAULT FALSE, -- Requires Multi-Factor
Authentication (mitmefaktoriline autentimine) for privileged accounts
    is_active BOOLEAN DEFAULT TRUE, -- Supports temporary account
suspension during long absences
    created_at TIMESTAMPTZ DEFAULT CURRENT_TIMESTAMP
);

-- 2. E-ITS Standard Roles (E-ITS standardrollid)
-- Roles must strictly map to E-ITS documentation terminology.
CREATE TABLE e_its_roles (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    role_name VARCHAR(100) UNIQUE NOT NULL,
    description TEXT

```

```

);

-- Seed mandatory E-ITS roles (Kohustuslike E-ITS rollide
alglaadimine)
INSERT INTO e_its_roles (role_name, description) VALUES
('Infoturbejuht', 'Information Security Officer: Infoturbeprotsessi
juhtimine ja koordineerimine'),
('IT-talitus', 'IT Department: IT-süsteemide haldus ja turvameetmete
rakendamine'),
('Juhtkond', 'Management Board: Üldvastutus ja ressursside eraldamine
infoturbele');

-- 3. Role Assignments (Kasutajate ja rollide seostamine)
-- Enforces segregation of duties (kohustuste lahusus) and least
privilege.
CREATE TABLE user_roles (
    user_id UUID REFERENCES local_users(id) ON DELETE CASCADE,
    role_id UUID REFERENCES e_its_roles(id) ON DELETE CASCADE,
    granted_by UUID REFERENCES local_users(id),
    granted_at TIMESTAMPTZ DEFAULT CURRENT_TIMESTAMP,
    PRIMARY KEY (user_id, role_id)
);

-- 4. Audit Trail (Auditilogi)
-- Crucial for RIA audits. Must log all permission changes.
-- Uses JSONB for flexible historical state storage.
CREATE TABLE audit_log (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    table_name VARCHAR(100) NOT NULL,
    record_id UUID NOT NULL,
    action_type VARCHAR(10) NOT NULL CHECK (action_type IN ('INSERT',
'UPDATE', 'DELETE')),
    old_data JSONB,
    new_data JSONB,
    changed_by UUID REFERENCES local_users(id),
    changed_at TIMESTAMPTZ DEFAULT CURRENT_TIMESTAMP
);

```

4. Development Directives for OpenCode

1. **Strict Relational Integrity:** Enforce Foreign Keys (ON DELETE CASCADE where appropriate) to prevent orphan records, which violate data integrity (*andmete terviklus*).
2. **Audit Automation:** You must write a PostgreSQL Trigger function (*andmebaasi trigger*) that automatically captures INSERT, UPDATE, and DELETE events on the user_roles table and inserts the JSONB diff into the audit_log table 10. This guarantees tamper-proof evidence (*asitõendite turve*) 11, 12 without relying on application-layer logic.

